UNIT 3 · TOPIC 3.4

Firewall Access Controls

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following best describes a stateless packet-filtering firewall?

○ A. It operates at the application layer and can inspect the content of HTTP requests for malicious payloads.

○ B. It maintains a record of active connections and automatically allows return traffic for established sessions.

● C. It inspects each packet independently based on header fields such as source IP, destination IP, and port number, without tracking connection state.

○ D. It encrypts all outbound packets before forwarding them to the next network segment.

Correct answer: C

Why: A stateless packet-filtering firewall examines each packet in isolation, applying permit/deny rules based solely on Layer 3–4 header fields (source/destination IP, protocol, port). It holds no memory of previous packets or session state. This distinguishes it from stateful inspection firewalls, which track the full TCP connection lifecycle and automatically permit return traffic for established sessions.

*Why the others are wrong: **A**, Describes a next-generation or application-proxy firewall, which operates at Layer 7. **B**, Describes a stateful inspection firewall; a common confusion because both types filter traffic using ACL rules. **D**, Describes a VPN gateway or IPsec tunnel endpoint, encryption is not a firewall function.*

2. Which of the following is a capability of a next-generation firewall (NGFW) that is NOT available in a traditional stateless packet-filtering firewall?

○ A. Blocking traffic by destination port number

○ B. Applying rules based on source IP address ranges

● C. Deep packet inspection of application-layer payloads

○ D. Denying all inbound ICMP traffic

Correct answer: C

Why: NGFWs operate at Layer 7 (application layer) and perform deep packet inspection, examining payload content, identifying applications regardless of port, detecting malware signatures, and applying user-identity-based policies. Traditional stateless packet-filtering firewalls examine only Layer 3–4 headers and cannot inspect payload content.

*Why the others are wrong: **A**, Port-based filtering is a basic function of any packet-filtering firewall ACL. **B**, Source IP filtering is also a core packet-filtering capability. **D**, Denying ICMP by protocol type is achievable with a standard stateless ACL rule.*

3. Which type of firewall intercepts all traffic between a client and a server, makes requests on the client's behalf, and thereby hides internal IP addresses from external hosts?

○ A. Stateful inspection firewall

○ B. Stateless packet-filtering firewall

● C. Application proxy firewall

○ D. Unified Threat Management (UTM) device

Correct answer: C

Why: An application proxy (or proxy firewall) sits between clients and servers, terminating each connection and re-initiating it on the client's behalf. External servers only see the proxy's IP, hiding internal network addresses. The proxy also performs full application-layer inspection. A stateful firewall tracks sessions but forwards packets directly, it does not act as an intermediary.

*Why the others are wrong: **A**, Stateful inspection tracks TCP state but passes packets through without proxying them. **B**, Stateless packet filtering passes or drops packets at L3/L4 with no proxying capability. **D**, UTM devices bundle multiple security functions (AV, IPS, content filtering) but the proxying function specifically defines an application proxy, UTM is not a firewall type in itself.*

4. A firewall's ACL contains the following three rules applied top-to-bottom:

1. Permit TCP any → 192.168.10.5 port 443
2. Permit TCP any → 192.168.10.5 port 80
3. Deny IP any any

Which statement best explains the behavior of this ACL?

○ A. All traffic destined for 192.168.10.5 is permitted, regardless of protocol or port.

○ B. UDP traffic to 192.168.10.5 on port 443 is permitted by rule 1 because the port number matches.

○ C. The deny rule at position 3 prevents rules 1 and 2 from ever being evaluated.

● D. HTTPS and HTTP traffic to 192.168.10.5 is permitted; all other traffic is denied by the catch-all rule.

Correct answer: D

Why: ACLs are evaluated top-to-bottom and stop at the first matching rule. Rule 1 permits inbound TCP 443 (HTTPS) to the server; Rule 2 permits TCP 80 (HTTP). Any packet not matching rules 1 or 2 continues to Rule 3, the explicit catch-all deny. A packet matched by Rule 1 or 2 never reaches Rule 3. The explicit deny (rather than relying on the implicit deny) also generates a log entry for every blocked packet, supporting audit requirements per NIST SP 800-41.

*Why the others are wrong: **A**, Only TCP port 443 and TCP port 80 are permitted, not all protocols or ports to that destination. **B**, Rule 1 specifies TCP as the protocol; UDP port 443 (used by QUIC/HTTP3) would not match and would be dropped by Rule 3. **C**, Rule 3 is evaluated last, only for packets that did not match any earlier rule; it cannot retroactively cancel earlier permits.*

5. Adams County Hospital has a public web server (203.0.113.10) and an internal patient-records file server (10.0.0.5). A network engineer is deploying two firewalls: Firewall A between the internet and a DMZ, and Firewall B between the DMZ and the internal LAN.

Which placement strategy best implements defense-in-depth for this architecture?

○ A. Firewall A filters all external traffic; Firewall B is configured to allow all DMZ-to-LAN traffic by default to avoid impeding clinical staff.

● B. Firewall A restricts inbound internet traffic to the web server on permitted ports only; Firewall B independently restricts DMZ-to-LAN traffic to only permitted internal services.

○ C. Both firewalls use identical ACLs to ensure consistent rule enforcement across both boundaries.

○ D. Firewall A handles all inbound traffic; Firewall B handles all outbound traffic, with no overlap in rule scope.

Correct answer: B

Why: Defense-in-depth requires each firewall to independently enforce least-privilege access at its specific trust boundary. Firewall A restricts internet access to the web server (e.g., TCP 80/443), isolating the DMZ from the broader internet. Firewall B then independently controls what the DMZ may access on the internal LAN, ensuring a compromised web server cannot directly reach the patient-records file server. Per NIST SP 800-41, each firewall should be configured for its specific network boundary, not as a copy of another.

*Why the others are wrong: **A**, Allowing all DMZ-to-LAN traffic at Firewall B completely eliminates the second layer of protection; a compromised DMZ host gains full internal access. **C**, Identical ACLs provide no additional layer of defense; the two firewalls protect different trust boundaries requiring different rule sets. **D**, Inbound/outbound direction is not the functional distinction between the two firewalls in a DMZ architecture; both firewalls handle both directions at their respective boundaries.*

6. Which of the following best explains why security best practice recommends including an explicit "Deny IP any any" rule at the end of a firewall ACL, even though most firewalls already apply an implicit deny to unmatched traffic?

● A. It makes the deny policy visible in firewall logs, creating an audit trail of all blocked traffic that auditors and incident responders can review.

○ B. It accelerates rule processing by giving the firewall a defined terminal condition that stops evaluation early.

○ C. It prevents the firewall from forwarding any traffic until at least one permit rule has been matched first.

○ D. It overrides all preceding permit rules, giving administrators a quick kill-switch to shut down all traffic in an emergency.

Correct answer: A

Why: The implicit deny at the end of an ACL blocks unmatched traffic but generates no log entry. An explicit "Deny IP any any log" rule records every blocked packet, source/destination IP, protocol, port, timestamp, and matched rule, providing an audit trail required by compliance frameworks such as HIPAA and aligned with NIST SP 800-41 guidance on firewall logging. Without it, blocked traffic is invisible in logs, hampering both auditing and incident investigation.

*Why the others are wrong: **B**, ACL evaluation is strictly sequential and does not accelerate based on the presence of a terminal rule. **C**, No such prerequisite exists; permit rules are independent of the deny rule's position. **D**, Rules are evaluated top-to-bottom and stop at the first match; a final deny rule only applies to packets that reached it, it cannot retroactively cancel earlier permit matches.*

7. A security team reviewing Adams County Hospital's network proposes removing Firewall B, the firewall between the DMZ and the internal LAN, to reduce latency for clinical staff accessing the patient-records file server.

Which evaluation of this proposal is most accurate?

○ A. The proposal is sound because Firewall A already filters all external threats before they reach the internal network.

○ B. The proposal is acceptable provided the web server runs host-based intrusion detection software to compensate.

○ C. The proposal is acceptable because the file server's operating system firewall can enforce equivalent access restrictions.

● D. The proposal eliminates a critical security layer; a compromised DMZ web server could then move laterally to the file server containing protected health information with no intervening control.

Correct answer: D

Why: Firewall B enforces the trust boundary between the DMZ and the internal LAN. Removing it means a successful compromise of the public-facing web server, a common attack vector via web exploits, provides direct, unobstructed access to the patient-records file server. This violates HIPAA's requirement to protect PHI through layered technical safeguards and directly contradicts NIST SP 800-41 guidance on dual-firewall DMZ architectures. The latency reduction is not a valid justification for eliminating a defense layer protecting sensitive medical records.

*Why the others are wrong: **A**, Firewall A only controls traffic crossing the internet-to-DMZ boundary; it has no visibility into lateral movement between the DMZ and the internal LAN. **B**, HIDS detects threats but cannot enforce network-layer access controls; it also runs on a potentially compromised host and may be disabled by an attacker. **C**, Host-based firewalls can be disabled or bypassed once an attacker gains foothold on the web server; a separate network firewall provides an independent, externally enforced control that the attacker cannot easily tamper with.*

8. When evaluating firewall placement strategies, which of the following best describes the primary risk of connecting a public-facing web server directly to the internal LAN (with no DMZ) when only a single perimeter firewall is deployed?

○ A. The web server will be unable to serve HTTPS traffic because the perimeter firewall will block port 443 inbound.

○ B. Without a DMZ, the perimeter firewall cannot perform stateful inspection.

○ C. Firewall processing overhead increases significantly because the firewall must perform deep inspection on all HTTP traffic to the web server.

● D. The inbound port rules required to serve public traffic create a pathway that, if exploited, could enable an attacker to reach all other systems on the same internal network segment.

Correct answer: D

Why: Placing a public-facing server on the internal LAN requires opening inbound rules (e.g., TCP 80/443) that point directly into the same network segment as sensitive internal systems. A successful web server compromise gives an attacker lateral access to internal resources, such as databases, file servers, or workstations, with no intervening firewall. A DMZ isolates the public server so that even complete server compromise does not grant direct access to the internal LAN without traversing a second independently configured firewall.

*Why the others are wrong: **A**, Port 443 can be permitted regardless of network architecture; this is a rule configuration choice, not a structural constraint. **B**, Stateful inspection is a firewall capability independent of network topology; a single-firewall flat network can still perform stateful inspection. **C**, HTTP inspection overhead is determined by firewall capability (e.g., NGFW vs packet filter), not by whether a DMZ exists.*

9. A HIPAA-covered healthcare organization is evaluating three firewall strategies:

Strategy 1: Single perimeter firewall with all servers on a flat internal LAN.
Strategy 2: Dual-firewall DMZ, public servers in the DMZ, patient-record systems on a separate internal LAN behind a second firewall.
Strategy 3: Single next-generation firewall (NGFW) with deep packet inspection at the perimeter only; no DMZ.

Which evaluation correctly identifies the most appropriate strategy and its primary justification?

○ A. Strategy 1 is best because it minimizes rule complexity and reduces administrative overhead.

● B. Strategy 2 is best because it isolates public-facing infrastructure from systems containing protected health information, providing segmented defense-in-depth at the network layer.

○ C. Strategy 3 is best because NGFW deep packet inspection eliminates the need for physical or logical network segmentation.

○ D. All three strategies are equivalent in security if the firewall ruleset is sufficiently strict.

Correct answer: B

Why: NIST SP 800-41 and HIPAA's Technical Safeguard standard both support isolating PHI systems from public-facing infrastructure using layered network controls. Strategy 2's dual-firewall DMZ ensures that even total compromise of a public server cannot directly reach PHI systems without traversing a second, independently enforced firewall. Strategy 3 improves threat detection at the perimeter but does not segment the network, a compromised internal system or a firewall zero-day leaves all systems equally exposed. Strategy 1 concentrates all risk at a single control point, with public and sensitive systems sharing the same logical network.

*Why the others are wrong: **A**, Simplicity of administration is not a security justification; reducing rule complexity at the cost of network segmentation increases attack surface. **C**, NGFW inspection is limited to traffic that crosses the firewall; it cannot prevent lateral movement between systems on the same internal segment after initial compromise. **D**, Ruleset strictness cannot compensate for placing PHI systems on the same network segment as public-facing servers; network topology is an independent security control layer.*

10. Which of the following ACL entries correctly permits only inbound HTTPS traffic from any external host to the web server at 203.0.113.10?

● A. Permit TCP any → 203.0.113.10 port 443

○ B. Permit UDP any → 203.0.113.10 port 443

○ C. Permit TCP any → 203.0.113.10 port 80

○ D. Permit IP any → 203.0.113.10

Correct answer: A

Why: HTTPS runs over TCP on port 443. A correct ACL entry must specify protocol = TCP, destination = 203.0.113.10, and destination port = 443. Option C uses port 80 (HTTP, not HTTPS). Option B incorrectly specifies UDP, standard HTTPS uses TCP (UDP port 443 is used by QUIC/HTTP3 but is not the default). Option D permits all IP traffic to the server regardless of protocol or port, which violates the principle of least privilege.

*Why the others are wrong: **B**, HTTPS runs over TCP, not UDP by default; this rule would not permit standard HTTPS connections. **C**, Port 80 is HTTP (cleartext), not HTTPS; this rule permits the wrong protocol. **D**, Permitting all IP traffic opens every protocol (UDP, ICMP, etc.) to the server, far broader than required.*

11. Which of the following best describes the primary purpose of enabling logging on firewall rules?

● A. Logging creates a timestamped audit trail of permitted and denied traffic that can be used for incident investigation and compliance reporting.

○ B. Logging speeds up packet processing by caching the results of frequently matched rules.

○ C. Logging automatically blocks repeated connection attempts from the same source IP address.

○ D. Logging encrypts sensitive traffic headers before the firewall forwards packets to internal systems.

Correct answer: A

Why: Firewall logs record metadata for each matched packet: source/destination IP, protocol, port, timestamp, action taken (permit/deny), and the rule matched. This data is essential for forensic investigation of security incidents, detecting anomalous traffic patterns, and demonstrating compliance with frameworks such as HIPAA and PCI-DSS. Logging does not affect throughput, automatically block traffic, or encrypt data.

*Why the others are wrong: **B**, Logging adds minor processing overhead for writing entries, it does not cache or accelerate rule evaluation. **C**, Automatic blocking based on repeated connection attempts is the function of an intrusion prevention system (IPS) or rate-limiting rule, not firewall logging itself. **D**, Encryption is the function of a VPN or TLS termination point, not firewall logging.*

12. A firewall rule reads: "Deny TCP 10.0.0.0/8 → any port 23." What traffic does this rule block?

○ A. All outbound traffic originating from any host within the 10.0.0.0/8 network

○ B. All TCP traffic between the 10.0.0.0/8 network and the internet, regardless of port

○ C. SSH traffic from any external host destined for the 10.0.0.0/8 network on port 23

● D. Telnet traffic originating from any host within the 10.0.0.0/8 internal network destined for any external host

Correct answer: D

Why: TCP port 23 is Telnet, an unencrypted remote access protocol. This rule denies all TCP sessions sourced from any host within the 10.0.0.0/8 subnet (the entire internal network) heading to port 23 on any destination. It is a standard security control to prevent use of cleartext Telnet from internal systems. It does not affect all outbound traffic (A), SSH traffic on port 22 (C), or TCP traffic on other ports (B).

*Why the others are wrong: **A**, The rule is constrained to TCP port 23, it does not affect traffic on other ports or protocols. **B**, The rule specifies port 23 only; TCP traffic on any other port from this subnet is unaffected. **C**, SSH uses port 22, not 23; additionally, the source in this rule is the internal 10.0.0.0/8 network, not external hosts.*

13. Firewall A at Adams County Hospital must allow external patients to access the appointment web server (203.0.113.10) over HTTPS only, while blocking all other inbound traffic. The firewall is stateful.

Which pair of ACL rules, applied in order, correctly implements this requirement?

● A. Rule 1: Permit TCP any → 203.0.113.10 port 443 | Rule 2: Deny IP any any

○ B. Rule 1: Permit IP any → 203.0.113.10 | Rule 2: Deny TCP any → 203.0.113.10 port 80

○ C. Rule 1: Deny IP any any | Rule 2: Permit TCP any → 203.0.113.10 port 443

○ D. Rule 1: Permit UDP any → 203.0.113.10 port 443 | Rule 2: Deny IP any any

Correct answer: A

Why: Rule 1 explicitly permits inbound TCP 443 (HTTPS) from any source to the web server. Rule 2 is an explicit catch-all deny for all remaining traffic. Because the firewall is stateful, return traffic for established TCP 443 sessions is automatically permitted by the connection state table, no separate outbound rule is needed. Option C places the deny rule first, blocking all traffic before Rule 2 can match anything. Option B permits all IP traffic to the server (overly permissive). Option D specifies UDP, which is not the transport protocol for standard HTTPS.

*Why the others are wrong: **B**, Permitting all IP traffic to 203.0.113.10 allows ICMP, UDP, and all TCP ports, far broader than HTTPS only; Rule 2 then has nothing meaningful to restrict. **C**, ACL rules are evaluated top-to-bottom; placing "Deny IP any any" first blocks all traffic before Rule 2 is ever evaluated. **D**, Standard HTTPS uses TCP; UDP 443 is used by QUIC/HTTP3 and would not support conventional HTTPS sessions.*

14. Firewall B at Adams County Hospital must ensure that only internal workstations on the 10.10.0.0/24 subnet can access the patient-records file server (10.0.0.5) over SMB (TCP port 445). All other traffic to the file server must be denied.

Which ACL, applied on Firewall B's inbound interface, correctly implements this?

○ A. Permit TCP 10.10.0.0/24 → 10.0.0.5 port 80 | Deny IP any any

○ B. Permit IP 10.10.0.0/24 → any | Deny TCP any → 10.0.0.5 port 445

○ C. Permit TCP any → 10.0.0.5 port 445 | Deny IP any any

● **D. Permit TCP 10.10.0.0/24 → 10.0.0.5 port 445 | Deny IP any any**

Correct answer: D

Why: Option D restricts SMB access to 10.0.0.5 specifically to authorized workstations in the 10.10.0.0/24 subnet, enforcing least-privilege network access at the protocol and destination level. The catch-all deny blocks everything else. Option C permits any host, including a compromised DMZ server, to reach the file server over SMB. Option B permits all IP traffic from the workstation subnet to any destination, which is far too broad. Option A uses port 80 (HTTP) instead of port 445 (SMB), failing to permit the required protocol.

*Why the others are wrong: **A**, Port 80 is HTTP; the file server communicates over SMB (port 445), so this rule would never permit the intended traffic. **B**, Permitting all IP traffic from the subnet to any destination allows workstations to reach systems beyond the file server, violating least-privilege. **C**, Permitting any host to reach the file server on port 445 includes DMZ servers and potential attackers who have already bypassed the perimeter.*

15. A network administrator configures the following ACL on a firewall:

Rule 1: Deny TCP 192.168.50.0/24 → 10.0.0.5 port 445
Rule 2: Permit TCP 192.168.50.0/24 → 10.0.0.5 port 445
Rule 3: Deny IP any any

A workstation at 192.168.50.25 attempts to open an SMB session with the file server at 10.0.0.5. What happens?

● **A. The connection is denied by Rule 1, because ACLs match top-to-bottom and the first matching rule wins.**

○ B. The connection is permitted by Rule 2 because it is a more specific (explicit permit) rule that overrides the earlier deny.

○ C. The connection is permitted because Rule 3 is the final authority and it overrides both preceding rules.

○ D. The connection fails because SMB is blocked by default on all enterprise firewalls regardless of ACL configuration.

Correct answer: A

Why: ACL rules are evaluated strictly top-to-bottom; the first matching rule determines the action and evaluation stops. Rule 1 matches the packet (source: 192.168.50.0/24, destination: 10.0.0.5, TCP port 445) and denies it, Rule 2 is never evaluated. Rule specificity does not override rule order in standard ACL processing. This is a common and dangerous

misconfiguration: placing a deny rule above the intended permit rule silently blocks legitimate traffic while appearing syntactically correct.

*Why the others are wrong: **B**, Standard ACL processing does not rank rules by specificity; order is determined by position in the list, not by permit/deny status. **C**, Rules are evaluated top-to-bottom and stop at the first match; Rule 3 is only reached by packets that did not match Rules 1 or 2. **D**, SMB is not inherently blocked by enterprise firewalls; ACL rules explicitly define what is permitted or denied, there is no protocol-level default block.*

16. You are implementing Firewall A for Adams County Hospital. The requirements are:

(1) External patients can access the web application server (203.0.113.10) over both HTTPS (TCP 443) and HTTP (TCP 80).

(2) External DNS resolution requests (UDP port 53) to the hospital's public DNS server (203.0.113.20) must be permitted.

(3) All other inbound traffic must be denied and logged.

Which ACL set below correctly implements all three requirements?

- ○ A. 1. Permit IP any → 203.0.113.10
  2. Permit UDP any → 203.0.113.20 port 53
  3. Deny IP any any log
- ○ B. 1. Deny IP any any log
  2. Permit TCP any → 203.0.113.10 port 80
  3. Permit TCP any → 203.0.113.10 port 443
  4. Permit UDP any → 203.0.113.20 port 53
- ○ C. 1. Permit TCP any → 203.0.113.10 port 443
  2. Deny IP any any log
  3. Permit TCP any → 203.0.113.10 port 80
  4. Permit UDP any → 203.0.113.20 port 53
- **● D. 1. Permit TCP any → 203.0.113.10 port 80**
  2. Permit TCP any → 203.0.113.10 port 443
  3. Permit UDP any → 203.0.113.20 port 53
  4. Deny IP any any log

Correct answer: D

Why: Option D places all three permit rules before the catch-all deny, respecting top-to-bottom ACL evaluation. Rules 1 and 2 permit HTTP and HTTPS to the web server; Rule 3 permits DNS queries to the DNS server. Rule 4's "Deny IP any any log" blocks all remaining traffic and generates a log entry for every blocked packet, essential for HIPAA audit trails and NIST SP 800-41-aligned logging practice. Option B places the deny first, blocking all traffic before any permit rule is evaluated. Option C inserts the deny between permit rules, silently blocking HTTP and DNS traffic. Option A uses an overly permissive "Permit IP any → 203.0.113.10" that opens all protocols to the web server.

*Why the others are wrong: **A**, "Permit IP any → 203.0.113.10" allows all protocols (ICMP, UDP, all TCP ports) to the web server, violating least-privilege; only HTTP and HTTPS should be permitted. **B**, The deny rule at position 1 matches every packet before rules 2–4 can be evaluated; no traffic reaches the web server or DNS server. **C**, The deny at position 2 blocks all traffic not yet matched by Rule 1 (HTTPS only); HTTP traffic (port 80) and DNS traffic (UDP 53) never match a permit rule and are silently dropped.*

17. A junior administrator configures the following ACL on Firewall B to control access to the patient-records file server (10.0.0.5):

Rule 1: Permit TCP 10.10.0.0/24 → 10.0.0.5 port 445
Rule 2: Permit TCP 172.16.0.0/16 → 10.0.0.5 port 445
Rule 3: Permit TCP 203.0.113.10 → 10.0.0.5 port 445
Rule 4: Deny IP any any

A senior engineer flags Rule 3 as a critical security flaw. Which explanation is most accurate?

● **A. Rule 3 permits the DMZ web server to access the internal patient-records file server over SMB, enabling lateral movement from a compromised web server directly into systems containing protected health information.**

○ B. Rule 3 is redundant because the 203.0.113.10 address falls within the range already covered by Rule 2.

○ C. Rule 3 is incorrectly written because a web server communicates on TCP 443, not TCP 445, making the rule syntactically invalid.

○ D. Rule 3 should specify UDP instead of TCP because web servers communicate with file servers using a connectionless protocol.

Correct answer: A

Why: 203.0.113.10 is the public-facing web server residing in the DMZ. The entire purpose of Firewall B is to prevent DMZ hosts from directly accessing internal LAN resources. Rule 3 creates an explicit permission for the DMZ web server to reach the patient-records file server over SMB (port 445). If the web server is compromised, a high-probability scenario for any internet-facing application, an attacker can immediately pivot to the file server storing PHI with no additional barrier. This nullifies the DMZ's security value and violates the principle of isolation between public and internal systems.

*Why the others are wrong: **B**, 203.0.113.10 is a public IP address and does not fall within the 172.16.0.0/16 (RFC 1918 private) range; the address ranges are non-overlapping. **C**, TCP 445 is the SMB port used for file sharing; it is the correct protocol for a file server, and the rule is syntactically valid, the flaw is logical (wrong host permitted), not syntactic. **D**, SMB uses TCP, not UDP; and the issue with Rule 3 is which host is permitted, not which transport protocol is specified.*

18. After configuring and deploying Firewall B at Adams County Hospital, which set of post-implementation actions most completely satisfies both security best practice and HIPAA audit requirements?

○ A. Reboot the firewall to apply the configuration and verify that the administrative web interface is reachable from the LAN.

● **B. Test that permitted traffic flows succeed, test that denied traffic is blocked, review firewall logs to confirm denied packets are being recorded, and produce documentation of the final ACL with a justification for each rule.**

○ C. Export the ACL to a plain text file and email it to the IT director for sign-off.

○ D. Run an external port scan against the internal file server IP address to confirm that rules are blocking unauthorized access from the internet.

Correct answer: B

Why: NIST SP 800-41 and HIPAA's Technical Safeguard requirements both mandate technical validation and documentation of access control implementations. Testing permitted flows confirms the ACL allows intended traffic (functional correctness). Testing denied flows confirms unauthorized access is blocked (security correctness). Log review confirms the audit trail is active, critical for HIPAA's Audit Control standard, which requires recording and examining access to PHI systems. Rule-by-rule documentation with justifications creates the compliance evidence needed for audits and provides a baseline for future change management. Option A is a procedural step but far from complete. Option C lacks testing. Option D is technically flawed: an external scan targets the internal file server IP, which is not routable from the internet and would be stopped by Firewall A, it cannot validate Firewall B's rules.

*Why the others are wrong: **A**, Verifying administrative access confirms the firewall is reachable but says nothing about whether security rules are correctly enforced. **C**, Distributing an ACL export for approval is a governance step, not a substitute for technical testing and log verification. **D**, An internet-facing scan cannot reach a private internal IP; it would be blocked by Firewall A and would not test Firewall B's rules at all. Internal testing (e.g., from a DMZ host or test workstation) is required to validate Firewall B specifically.*